Introduction à la Sécurité Informatique – Contrôle sur machine

Gilles Grimaud

18/02/2026

Contexte général

On considère un *Proof of Concept* (PoC) simplifié de gestion de noms et de numéros de cartes bancaires. Dans ce système :

— les noms des utilisateurs sont stockés en clair,

— les numéros de carte bancaire sont chiffrés,

— la clé de chiffrement n'est disponible qu'après une phase de démarrage impliquant deux autorités distinctes,

— l'ensemble est volontairement biaisé et incomplet du point de vue de la sécurité.

Le PoC est fourni sous forme de scripts shell et d'un fichier de données. Le fonctionnement détaillé du système, le format des données et les choix cryptographiques sont décrits dans le fichier `README.md`, qui fait partie intégrante du sujet.

Important : ce PoC n'est pas un exemple de bonne pratique. Il sert uniquement de support pédagogique pour l'étude de failles et de mécanismes de sécurité.

Consignes

— Toutes les réponses doivent être rédigées dans un fichier nommé `ANSWERS.md`.

— Les réponses doivent être justifiées, de manière concise mais rigoureuse.

— Lorsque cela est pertinent, vous pouvez vous appuyer sur les propriétés des algorithmes cryptographiques utilisés.

Partie I – Compréhension du PoC

Cette première partie vise à vérifier votre compréhension du fonctionnement général du PoC.

Q1. Le PoC montre-t-il l'intention de mettre en place une authentification à deux facteurs ? Justifiez votre réponse en vous appuyant sur le rôle des différents éléments du système.

Q2. Quel est l'algorithme de chiffrement utilisé pour protéger les numéros de carte bancaire ?

Q3. Sans déchiffrer les données, est-il possible de savoir si deux utilisateurs utilisent la même carte bancaire ?
Justifiez votre réponse.

Partie II – Première famille d'attaques

Dans cette partie, on suppose que l'attaquant a réussi à obtenir un accès illégal au fichier servant de base de données (le fichier contenant les cartes bancaires chiffrées).

On suppose en revanche qu'il n'a **pas accès** à la clé maître, laquelle est uniquement présente en mémoire (ramdisk).

Q4. Comment l'attaquant peut-il modifier le fichier de données afin que, lors d'une lecture ultérieure, la valeur du numéro de carte bancaire déchiffrée ait son premier chiffre augmenté ou diminué de 1 (par exemple `2111` devient `3111`) ?

Justifiez précisément la technique employée.

Q5. Sachant qu'un numéro de carte bancaire est composé de 16 chiffres, peut-on modifier n'importe lequel de ces chiffres avec la même technique ?

Justifiez votre réponse.

Q6. Peut-on modifier un 17^e chiffre ?

Justifiez votre réponse.

Partie III – Seconde attaque : usurpation de paiement

On considère maintenant une attaque plus réaliste.

L'attaquant possède un compte client chez ce marchand. Il a réussi à consulter et modifier le fichier des cartes bancaires. Bien que le PoC utilise un simple fichier, on considère que dans un système réel, cette attaque pourrait résulter d'un accès direct à une base de données (par exemple via une injection SQL).

Q7. Comment l'attaquant peut-il régler ses propres factures avec la carte bancaire d'un autre client ?

Décrivez le scénario d'attaque.

Q8. Quels éléments du modèle de données ou du schéma cryptographique rendent cette attaque possible ?

Q9. Une fois la faille de sécurité identifiée, comment les responsables du système peuvent-ils déterminer les comptes compromis (victimes et attaquants) ?

Partie IV – Contre-mesures et amélioration du schéma

Suite à vos remarques, le concepteur du système souhaite améliorer sa solution.

Q10. Le concepteur affirme que, de toute manière, si l'attaquant parvient à lire le code de l'application, par exemple le script `add.sh`, il pourra toujours contourner le nouveau schéma de protection.

Qu'en pensez-vous ? Justifiez votre réponse.

Q11. Pour éviter le problème identifié en partie III, il propose que le nom soit « répété » dans le chiffré, juste avant le numéro de carte bancaire en clair. Lors du déchiffrement, le programme vérifiera d'abord que le nom indiqué correspond bien à celui stocké en clair, et refusera l'opération s'il n'est pas identique.

Pourquoi l'attaquant pourra-t-il néanmoins s'approprier la carte bancaire d'un tiers ? Justifiez et précisez les conditions nécessaires à cette attaque.

Q12. Pour traiter le problème de la partie II, il propose d'ajouter un nouveau champ, à la suite des trois déjà présents. Ce champ contient le SHA-256 de l'IV concaténé avec la base64 de la carte bancaire. Ainsi, argumente-t-il, il ne serait plus possible de modifier l'IV sans que le système ne détecte le problème.

Que pensez-vous de cette contre-mesure ? Justifiez votre réponse.